Conti Ransomware Investigation with Splunk

TryHackMe Lab Report: Exchange web shell to ransomware execution

Author: Nikhil Gowda | Date: 2 November 2026 | Tools: Splunk Enterprise 8.2.2, Sysmon, IIS logs

1. Executive Summary

This report documents my investigation of a simulated Conti ransomware attack in the TryHackMe Conti lab. Working only in Splunk, I analysed Sysmon and IIS logs from a Microsoft Exchange server (**WIN-AOQKG2AS2Q7**, domain **bellybear.local**) and reconstructed the intrusion from the first foothold to the final ransomware execution.

The evidence shows that the attacker planted a web shell (**i3gfPctK1c2x.aspx**) in the Exchange OWA authentication directory, injected code into **lsass.exe** and **unsecapp.exe**, created a persistent local administrator account named **securityninja** with Remote Desktop rights, and finally ran a ransomware binary disguised as **cmd.exe** from the Administrator's Documents folder. That binary dropped a **readme.txt** ransom note in 19 locations, including the Downloads folders of several user profiles.

Key results at a glance

Finding	Result
Initial foothold	Web shell i3gfPctK1c2x.aspx in the Exchange OWA auth directory
Web shell usage	4 POST requests to /owa/auth/i3gfPctK1c2x.aspx
Process injection	2 CreateRemoteThread events: unsecapp.exe and lsass.exe
Persistence	Local user securityninja, added to Administrators and Remote Desktop Users
Ransomware binary	C:\Users\Administrator\Documents\cmd.exe (masquerading as cmd.exe)
Ransom note	readme.txt written in 19 file-creation events

2. Scope and Environment

The lab provides a Splunk instance loaded with Windows Sysmon logs (`WinEventLog:Microsoft-Windows-Sysmon/Operational`) and IIS logs from the compromised Exchange server. All searches used `index=*`. The activity in the logs took place on 8 September 2021. The hostnames, accounts and credentials in this report belong to the training lab.

Sysmon event IDs used in this investigation:

Event ID	Meaning	Used for
1	Process creation	net.exe commands, fake cmd.exe process and hashes
8	CreateRemoteThread	Process injection into lsass.exe and unsecapp.exe
11	File creation	Ransom note readme.txt and the process that wrote it

3. Threat Background

Researchers have associated three vulnerabilities with exploitation by the Conti ransomware operators. They affect Microsoft products and Fortinet FortiOS, and are summarised below. Knowing which flaws Conti favours helps prioritise patching and shapes what an analyst should hunt for.

CVE	Product	CVSS	Description
CVE-2020-0796	Microsoft (CoronaBlue / SMBGhost)	10.0	Critical RCE and privilege escalation; one of the top exploited vulnerabilities of 2020
CVE-2018-13379	Fortinet FortiOS	9.8	Critical RCE that allows unauthenticated attacks
CVE-2018-13374	Fortinet FortiOS	8.8	High-rated vulnerability used to compromise web applications

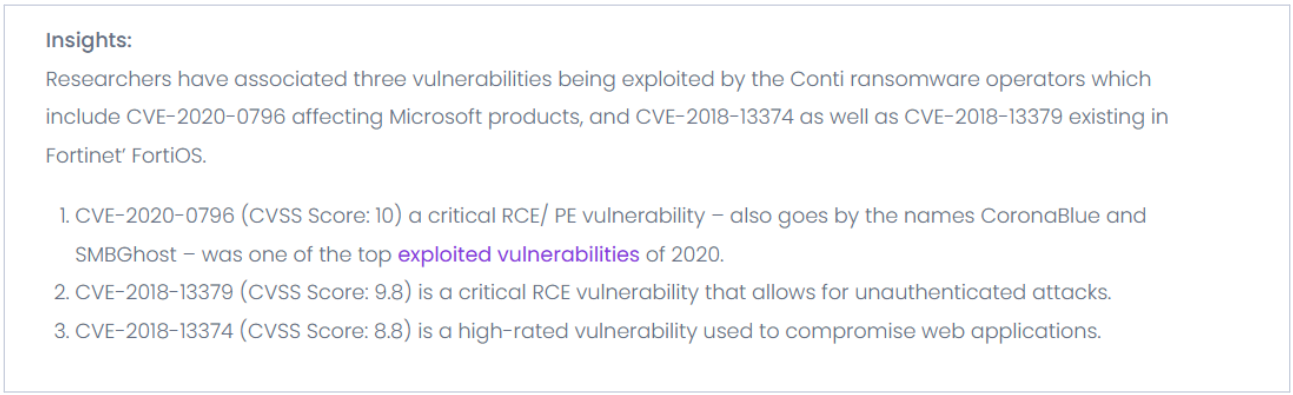


Figure 1: Researcher insights on vulnerabilities exploited by Conti operators

4. Attack Timeline

Stage	Evidence	Time in Splunk
Web shell activity	attrib.exe against i3gfPctK1c2x.aspx in the Exchange OWA auth directory	9/8/21 12:52:09 PM (Splunk display time)
Account creation	net user /add securityninja	2021-09-08 20:04:10 UTC
Privilege and RDP access	Added to Administrators and Remote Desktop Users	2021-09-08 20:04:10 to 20:04:11 UTC
Ransomware execution	cmd.exe from Administrator's Documents folder writes readme.txt	2021-09-08 20:08:34 UTC

Note: the web shell entry is shown in the Splunk display timezone, while the other entries come from the UTC time field. The two should be compared with care.

5. Detailed Findings

Finding 1: Web shell in the Exchange OWA directory

To start, I searched all indexes for the suspicious file name and highlighted the command line field.

```
index=* "i3gfPctK1c2x.aspx"
| highlight Commandline
```

The search returned 6 events. The Sysmon process creation event shows **attrib.exe** (OriginalFileName ATTRIB.EXE) running against the file, launched by **cmd.exe** as **NT AUTHORITY\SYSTEM** with the current directory `c:\windows\system32\inetsrv\`, the IIS working context. The host was WIN-AOQKG2AS2Q7.

```
attrib.exe -r \\win-aoqkg2as2q7.bellybear.local\C$\Program Files\Microsoft\Exchange Server\V
15\FrontEnd\HttpProxy\owa\auth\i3gfPctK1c2x.aspx
```

Analysis: An .aspx file with a random name inside the OWA auth directory, touched by a SYSTEM process spawned from the IIS context, is a strong web shell indicator. The -r switch clears the read-only attribute, which is usually done so a file can be modified or deleted. This may therefore be attacker cleanup or file manipulation, although the screenshot alone does not prove which.

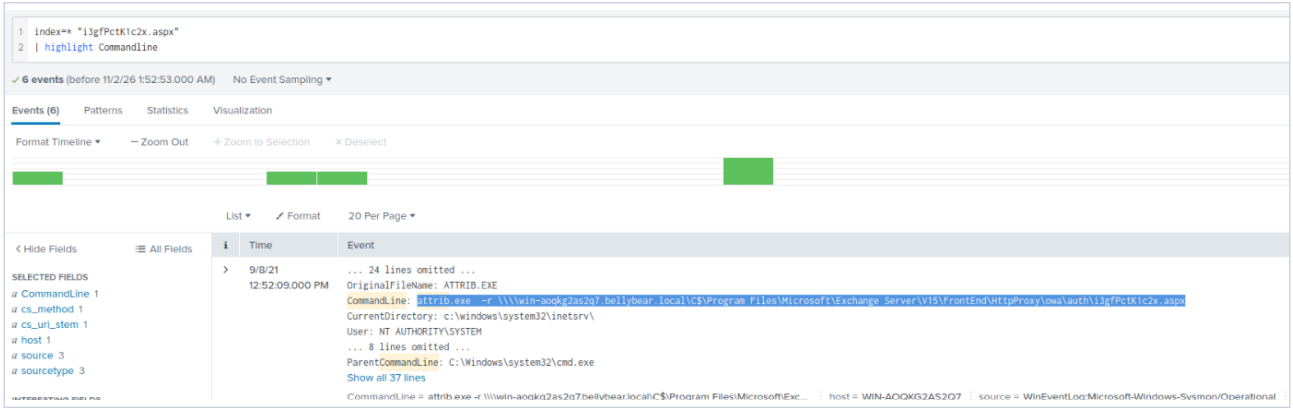


Figure 2: Sysmon event showing attrib.exe run against the web shell file

Finding 2: Web shell confirmed in IIS logs

Next I searched the IIS logs for POST requests to .aspx resources, since web shells are normally driven with POST requests.

```
index=* sourcetype=iis cs_method="POST" aspx
```

This returned 187 events. The `cs_uri_stem` field contained 6 distinct values:

cs_uri_stem	Count	Share
/ecp/DDI/DDIService.svc/GetList	171	91.444%
/owa/auth.owa	8	4.278%
/owa/auth/i3gfPctK1c2x.aspx	4	2.139%
/ecp/DDI/DDIService.svc/NewObject	2	1.07%
/ecp/DDI/DDIService.svc/GetObject	1	0.535%
/owa/lang.owa	1	0.535%

Analysis: The attacker sent 4 POST requests directly to the web shell, which confirms it was used and not just dropped. The large number of requests to the Exchange ECP DDIService endpoints (GetList, NewObject, GetObject) is consistent with exploitation of the Exchange control panel, in the style of ProxyShell, to plant the shell. This link is my interpretation of the request pattern.

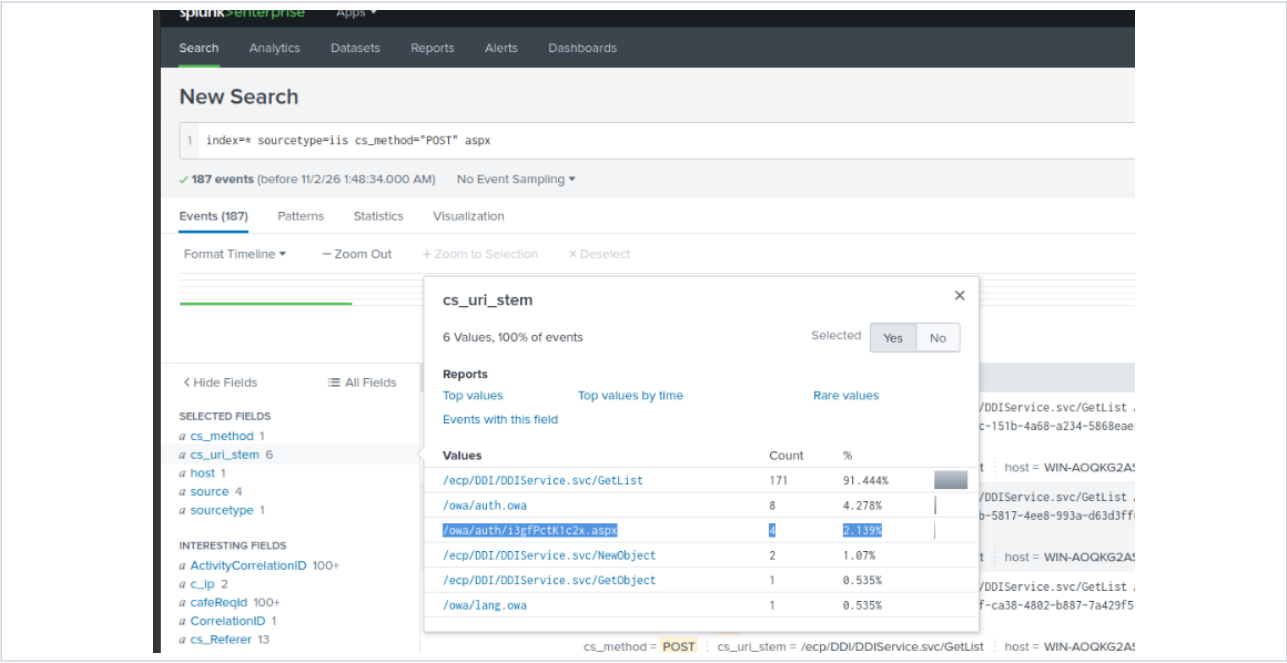


Figure 3: IIS POST requests grouped by cs_uri_stem

Finding 3: Process injection (Sysmon Event ID 8)

Sysmon Event ID 8 records CreateRemoteThread, where one process starts a thread inside another. I listed the target processes in the order they occurred.

```
index=*
 EventCode=8
| table TargetImage
| reverse
```

Two events were returned, targeting `C:\Windows\System32\wbem\unsecapp.exe` and `C:\Windows\System32\lsass.exe`.

Analysis: Remote threads in lsass.exe are a well-known step in credential theft, because LSASS holds credential material in memory. Injection into unsecapp.exe, a legitimate Windows binary, suggests the attacker hid malicious code inside a trusted process to evade detection. The source process is not visible in my screenshot, so adding SourceImage to the table would be a useful next step.

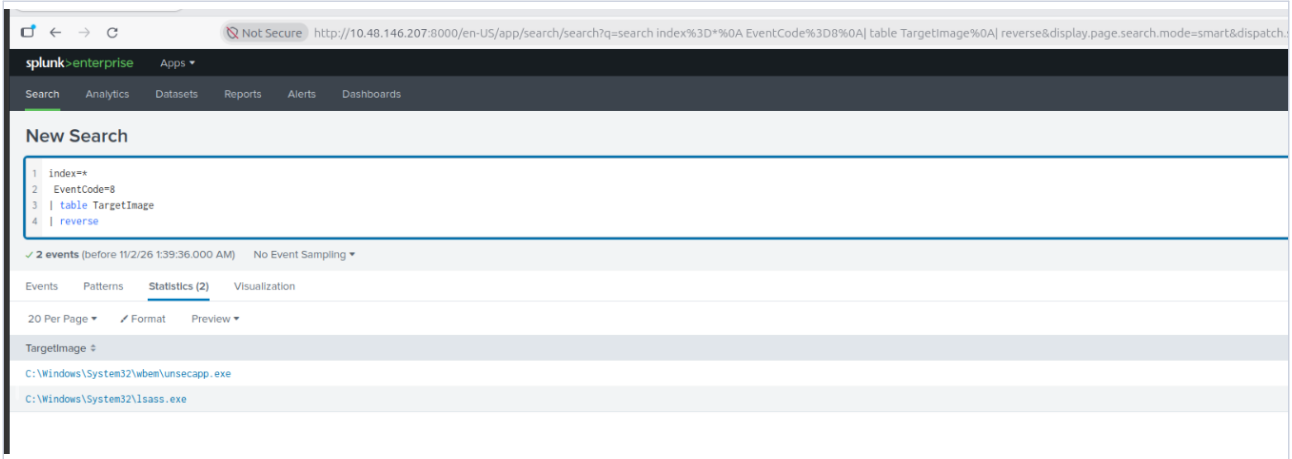


Figure 4: CreateRemoteThread events and their target images

Finding 4: Persistence through a new administrator account

To look for persistence, I searched process creation events for net.exe and sorted them in time order.

```
index=*
 EventCode=1 net.exe
| table UtcTime CommandLine
| reverse
```

The search returned 6 events, which are 3 distinct commands, each logged once as net and once as net1 (the helper binary net.exe launches). All occurred within about one second on 2021-09-08 starting at 20:04:10 UTC.

UTC time	Command line
2021-09-08 20:04:10.692	`net user /add securityninja hardToHack123$`
2021-09-08 20:04:10.745	`C:\Windows\system32\net1 user /add securityninja hardToHack123$`
2021-09-08 20:04:10.965	`net localgroup administrators securityninja /add`
2021-09-08 20:04:10.986	`C:\Windows\system32\net1 localgroup administrators securityninja /add`
2021-09-08 20:04:11.031	`net localgroup "Remote Desktop Users" "securityninja" /add`
2021-09-08 20:04:11.047	`C:\Windows\system32\net1 localgroup "Remote Desktop Users" "securityninja" /add`

Analysis: The attacker created the local user **securityninja**, added it to the local Administrators group and allowed it to log on through Remote Desktop. This gave persistent, privileged remote access that would survive removal of the web shell. The commands ran in quick succession, which suggests a script or an automated tool.

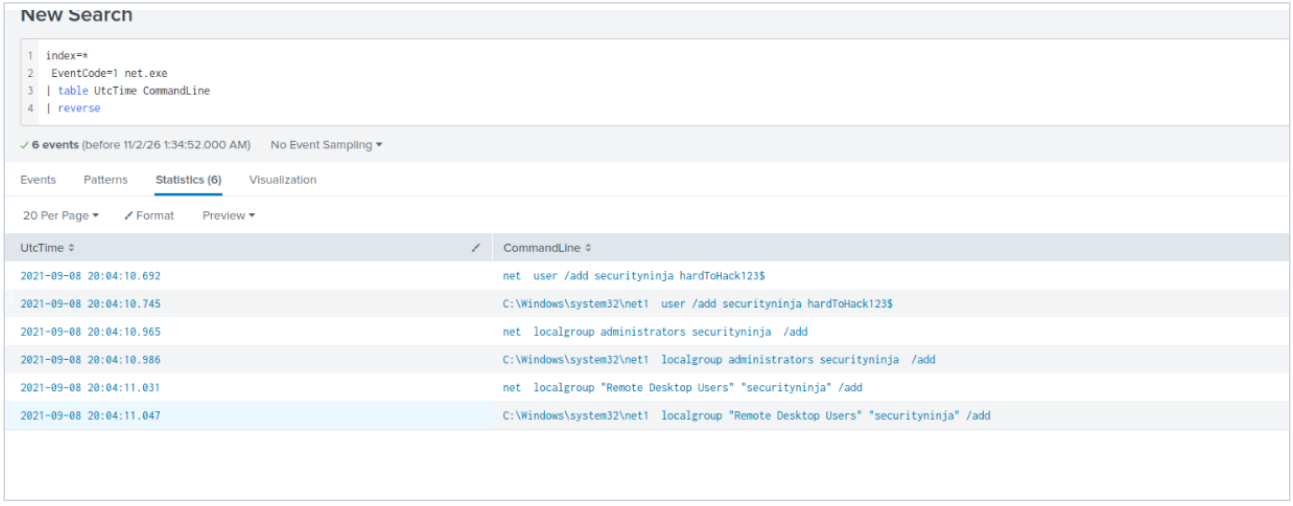


Figure 5: net.exe commands used to create and privilege the backdoor account

Finding 5: Ransom notes written across user profiles

To find the ransomware's visible output, I searched Sysmon file creation events (Event ID 11) that involve cmd.exe.

```
index=* EventCode=11 cmd.exe
```

This returned 19 events. In the `TargetFilename` field every value was a different path, each ending in **readme.txt** in a user's Downloads folder, for example:

TargetFilename (examples)
`C:\Users\.NET v4.5 Classic\Downloads\readme.txt`
`C:\Users\.NET v4.5\Downloads\readme.txt`
`C:\Users\Administrator.BELLYBEAR\Downloads\readme.txt`

Analysis: The same file name appearing across many profiles is typical ransomware behaviour, where a note is dropped into folders so that the victim is sure to see it. It marks the final impact stage of the intrusion.

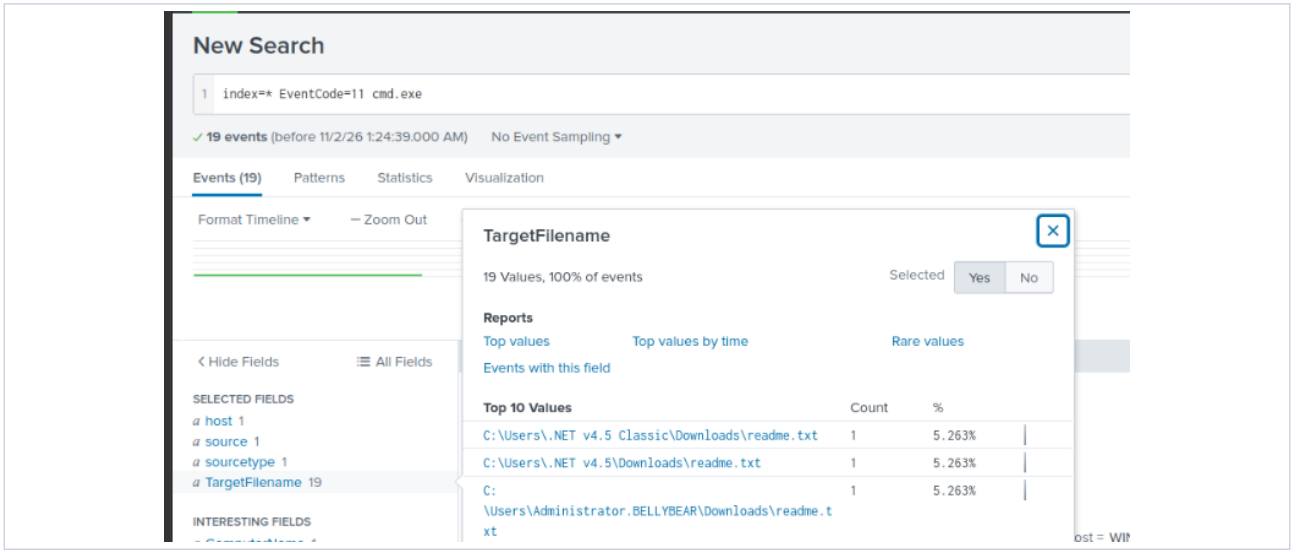


Figure 6: TargetFilename values showing readme.txt across user profiles

Finding 6: Ransomware binary disguised as cmd.exe

To identify which process wrote the ransom notes, I tabulated the time and the Image field for the same file creation events.

```
index=*
EventCode=11 cmd.exe
| table UtcTime Image
```

All 19 events came from `c:\Users\Administrator\Documents\cmd.exe`, with the first event at **2021-09-08 20:08:34.900**. This is about four and a half minutes after the backdoor account was created.

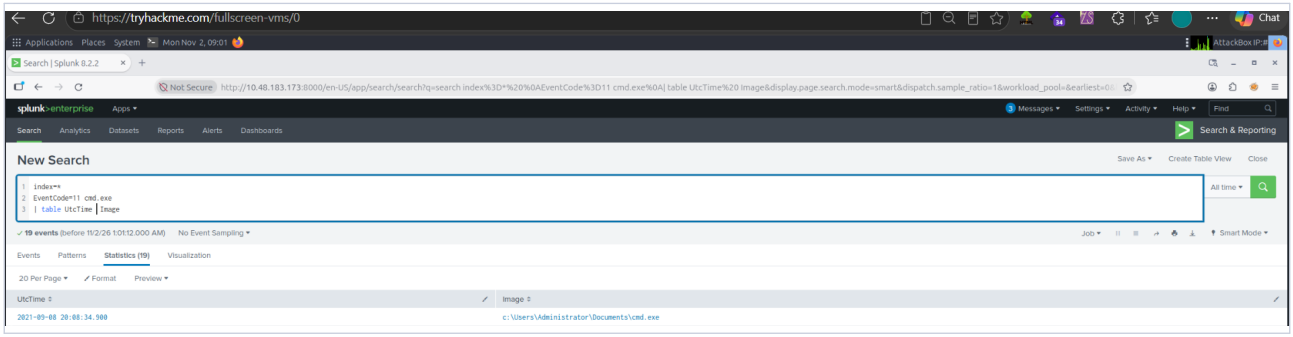


Figure 7: File creation events attributed to the cmd.exe in the Documents folder

I then pulled the process creation event for the same path to capture its hashes.

```
index=* cmd.exe
EventCode=1 Image="*\\Users\\*\\Documents\\cmd.exe"
| table Image CommandLine Hashes
```

Field	Value
Image	`C:\Users\Administrator\Documents\cmd.exe`
CommandLine	`cmd.exe`
MD5	`290C7DFB01E50CEA9E19DA81A781AF2C`
SHA256	`53B1C1B2F41A7FC300E97D036E57539453FF82001DD3F4ABF07F4896B1F9CA22`
IMPHASH	`23F815785DB238377F4513BE54DBA574`

Analysis: The genuine cmd.exe lives in C:\Windows\System32. A file with that name running from a user's Documents folder is masquerading as a system binary, and it is the process that produced the ransom notes. Its hashes are strong IOCs that can be checked against threat intelligence services and blocked across the environment.

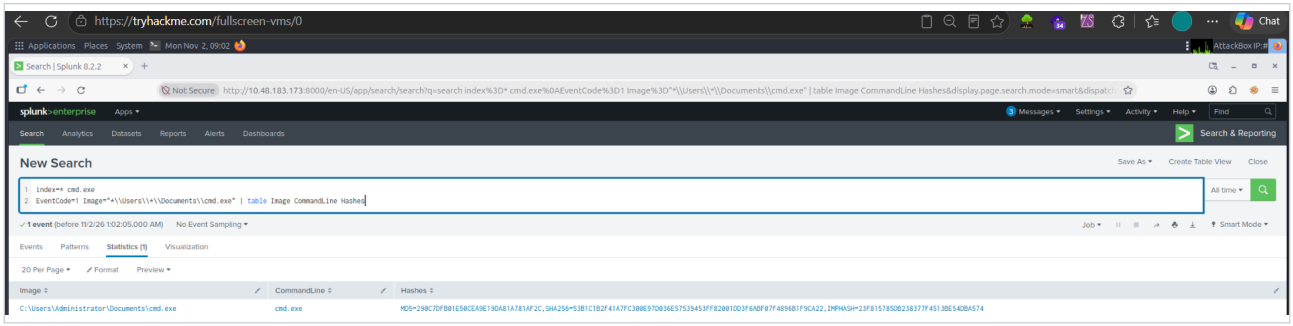


Figure 8: Process creation event with MD5, SHA256 and IMPHASH of the fake cmd.exe

6. MITRE ATT&CK Mapping

Tactic	Technique	Evidence
Initial Access	T1190 Exploit Public-Facing Application	Exchange ECP and OWA exploitation pattern
Persistence	T1505.003 Server Software Component: Web Shell	i3gfPctK1c2x.aspx
Persistence	T1136.001 Create Account: Local Account	net user /add securityninja
Privilege Escalation	T1078 Valid Accounts (privileged group membership)	Added to Administrators group
Lateral Movement	T1021.001 Remote Services: RDP	Added to Remote Desktop Users
Defense Evasion	T1055 Process Injection	CreateRemoteThread into unsecapp.exe and lsass.exe
Defense Evasion	T1036.005 Masquerading: Match Legitimate Name	cmd.exe in the Documents folder
Credential Access	T1003.001 OS Credential Dumping: LSASS Memory (likely)	Remote thread into lsass.exe
Impact	T1486 Data Encrypted for Impact	readme.txt written in 19 locations

7. Indicators of Compromise

Type	Value
Host	`WIN-AOQKG2AS2Q7 (bellybear.local)`
Web shell path	`C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\i3gfPctK1c2x.aspx`
Web shell URI	`/owa/auth/i3gfPctK1c2x.aspx`
Backdoor account	`securityninja`
Malicious file	`C:\Users\Administrator\Documents\cmd.exe`
MD5	`290C7DFB01E50CEA9E19DA81A781AF2C`
SHA256	`53B1C1B2F41A7FC300E97D036E57539453FF82001DD3F4ABF07F4896B1F9CA22`
IMPHASH	`23F815785DB238377F4513BE54DBA574`
Ransom note	`readme.txt in user Downloads folders`

8. Detection and Response Recommendations

Detection ideas

1. Alert on new .aspx files created under the Exchange FrontEnd and OWA directories, and on POST requests to unusual .aspx files in /owa/auth/.
2. Alert on net user /add and net localgroup administrators /add in Sysmon Event ID 1.
3. Alert on Sysmon Event ID 8 where TargetImage is lsass.exe.
4. Alert on system binary names such as cmd.exe running from outside C:\Windows\System32.
5. Alert on bursts of identical file creation, for example readme.txt, across many user profiles.

Response and hardening

1. Isolate the affected host, then remove the web shell and the fake cmd.exe.
2. Disable and delete the securityninja account.
3. Reset credentials exposed on the server, since LSASS was targeted.
4. Block the file hashes and hunt for them across the environment.
5. Patch Exchange and edge devices, including the Microsoft and FortiOS CVEs listed in section 3.
6. Restrict RDP exposure and keep offline, tested backups.

9. Conclusion

The lab shows a complete ransomware attack chain that can be reconstructed from Sysmon and IIS logs alone. The attacker gained a foothold through the Exchange server, used a web shell for access, injected into sensitive processes, created a hidden administrator account for persistence, and executed ransomware under a trusted file name. For a SOC analyst, the lessons are to monitor Exchange web directories, watch for account and group changes, treat LSASS access as high severity, and check where common system binaries are running from.

Skills demonstrated: Splunk SPL (table, reverse, highlight, field filtering), Sysmon event analysis (IDs 1, 8, 11), IIS log analysis, web shell identification, threat hunting, IOC extraction, MITRE ATT&CK mapping and incident reporting.